

INFORMATION SYSTEM AUDIT REPORT

**OF
XYZ BANK LIMITED**

April 22, 2026

CONFIDENTIAL

Submitted To:

XYZ Bank Limited

Kathmandu, Nepal

Submitted By:

Eminence Ways Pvt. Ltd.

Kathmandu, Nepal

Disclaimer

This Information Systems Audit Report is intended solely for the information and use of the management and Board of Directors of XYZ Bank Limited. This report is not intended to be and should not be used by anyone other than these specified parties. While every effort has been made to ensure the accuracy and completeness of the information presented, an audit provides reasonable assurance, not absolute assurance, that the information systems are free from material weaknesses.

Table of Contents

1. Executive Summary	3
2. Objectives of the Audit	3
3. Scope of the Audit	4
4. Audit Rating Criteria.....	5
5. Audit Methodology	5
6. Audit Finding, Risk and Recommendations	6
6.1. IT Governance and Management	6
6.2. Network Security.....	6
6.3. Application System	7
6.4. Vendor & Third-Party Management	7
6.5 Physical & Environmental Security	8
6.6. Human Resources and Administration.....	8
6.7. Business Continuity & Disaster Recovery (BCP/DR)	9
7. Conclusion	10

1. Executive Summary

Eminence Ways Pvt. Ltd. company was engaged by XYZ Bank Limited, Kathmandu, Nepal to conduct an information system (IS) Audit of its technology infrastructure, information security controls, and operational processes. The audit was conducted during April 2026 in accordance with internationally recognized standards including ISO 27001:2022, NRB IT Guidelines 2023, and Cyber Resilience Guideline 2023.

The audit covered seven key domains such as IT Governance and Management, Network Security, Application Security, Vendor and Third-Party Management, Physical and Environmental Security, Human Resources and Administration, and Business Continuity and Disaster Recovery (BCP/DR). The assessment was conducted through document reviews, interviews with key personnel, physical inspection of facilities, and technical assessment of IT systems and configurations.

The audit identified a total of 11 findings across the seven domains, comprising 3 Critical, 4 High, 2 Medium, and 2 Positive findings. Critical findings were identified in the areas of web banking session management, firewall configuration, and disaster recovery planning. High risk findings were noted in IT governance, network access controls, vendor management, and employee offboarding processes. Positive findings were documented in the areas of mobile banking application security and data center physical controls, where the bank demonstrated commendable security practices.

Based on the findings of this audit, the overall information security posture of XYZ Bank Limited is rated as Partially Satisfactory. While the bank has established admirable controls in physical security and mobile application authentication, significant gaps remain in critical areas including session management, firewall governance, multi-factor authentication, vendor risk management, and disaster recovery preparedness.

It is strongly recommended that the management of XYZ Bank Limited prioritize the remediation of Critical and High-risk findings within 30 days and address medium risk findings within 90 days to strengthen its overall security posture and ensure full compliance with NRB IT Guidelines 2023 and applicable regulatory requirements.

2. Objectives of the Audit

The primary objective of this Information Systems Audit is to conduct a comprehensive and independent evaluation of XYZ bank Limited company governance framework, information security controls, and operational processes. The audit aimed to identify vulnerabilities, assess compliance with applicable regulatory requirements, and provide actionable recommendations to strengthen the bank's overall security posture with legally also.

1. To evaluate the adequacy and effectiveness of the IT governance structure and policies in place XYZ bank Limited.
2. To assess the security of Network infrastructure which are critical such as firewalls, routers, servers, Active Directory (AD), and email systems.
3. To review the security controls for the web and mobile banking platforms which are the core Banking system.
4. To evaluate the bank's vendor and third-party risk management practices and supply chain integrations in the system.

5. To inspect the physical and Environmental security such as protection of data centers and office facilities against unauthorized access and environmental hazards.
6. To assess the competence of human resources security practices including onboarding, offboarding, administrative access controls, and security awareness training
7. To evaluate the Business Continuity (BCP) and Disaster Recovery (DR) for resilience and recoverability of critical systems.
8. To assess the bank's compliance with applicable regulatory requirements such as NRB IT Guidelines 2023 and Cyber Resilience Guideline 2023.

3. Scope of the Audit

The scope of this Information System Audit encompassed the IT infrastructure, information security controls and operational processes of XYZ Bank Limited, Kathmandu, Nepal. The audit was conducted during April 2026 and covered both the Head Office and the primary Data Center of the bank. The assessment was limited to systems, processes, and controls that were operational and accessible during the Audit.

The audit specifically covered the following domains and focus areas:

1. IT Governance: Alignment of IT strategy with business goals, organizational structure, and policy frameworks.
2. Network Security: Configuration and security of critical infrastructure including firewalls, routers, servers, Active Directory (AD), and email systems.
3. Application Security: Security controls for web and mobile banking platforms.
4. Vendor & Third-Party Management: Risk assessment of external service providers and the security of supply chain integrations.
5. Physical & Environmental Security: Protection of data centers and office facilities against unauthorized access and environmental hazards.
6. Human Resources & Administration: Employee onboarding/offboarding processes, security awareness training, and administrative access controls.
7. Business Continuity & Disaster Recovery (BCP/DR): Resilience of critical systems and the adequacy of failover and recovery procedures.

The following areas were outside the scope of this audit:

- Branch offices and regional locations other than the Head Office and primary Data Center.
- Financial audit, accounting controls, and non-IT operational processes.
- Source code review of banking applications, as source code was not made available during the audit period.
- Live penetration testing or active exploitation of production systems.
- Any systems, processes, or controls implemented after the conclusion of the audit period (post April 2026).

4. Audit Rating Criteria

The following rating criteria were used to classify the risk level of each audit finding identified during the Information Systems Audit of XYZ Bank Limited. Each finding was assigned a rating based on the potential impact and likelihood of occurrence.

Rating	Colour	Definition	Action Required
Critical	Dark Red	Severe vulnerability or control failure that poses an immediate threat to the bank's operations, confidentiality, or regulatory compliance. Exploitation could result in significant financial loss or reputational damage	Immediate remediation required within 7–15 days.
High	Red	Significant control weakness that could be exploited to cause major disruption, unauthorized access, or data breach if not addressed promptly.	Remediation is required within 30 days.
Medium	Orange	Moderate control gap that may lead to limited impact on operations or security if exploited. Risk is manageable but should be addressed in a timely manner.	Remediation required within 60–90 days.
Low	Green	Minor control deficiency with limited impact on operations. Risk is low and may be addressed through routine process improvements.	Remediation within 180 days or next audit cycle.
Positive	Teal	Area where the bank demonstrates strong controls, good practices, or commendable compliance. Documented to acknowledge good security posture.	Maintain and continue current practices.

5. Audit Methodology

The Information Systems Audit of XYZ Bank Limited was conducted using a structured and risk-based audit approach. The audit methodology was designed to ensure comprehensive coverage of all in-scope domains while maintaining objectivity and professional independence throughout the engagement. Evidence was gathered through multiple techniques to ensure findings are supported by sufficient and appropriate audit evidence.

1. Document Review: Reviewed existing IT policies, procedures, network diagrams, BCP/DRP documents, vendor contracts, and access control records provided by the bank.
2. Interview: Conducted structured interviews with key personnel including IT Manager, Network Administrator, HR Manager, and Operations staff to understand controls in practice.
3. Physical Observation: Physically inspected the data center, server room, and office facilities to observe access controls, environmental controls, CCTV systems, and physical security measures.
4. Technical Assessment: Performed configuration reviews of firewalls, servers, and Active Directory. Conducted vulnerability scanning using industry-standard tools to identify technical weaknesses.
5. Compliance Checklist: Evaluated controls against NRB IT Guidelines 2023, ISO 27001:2022, and Cyber Resilience Guideline 2023 using structured compliance checklists for each domain

6. Audit Finding, Risk and Recommendations

This section details the significant findings from our audit, categorized by control are, along with corresponding risks and recommendations for improvement.

6.1. IT Governance and Management

Finding 6.1.1: Lack of a dedicated Information Security Officer (ISO) with sufficient authority and independence.	Risk Level
	High
○ Risk: Without a dedicated ISO, critical security oversight is absent, leading to potential conflicts of interest and slow response to security incidents, significantly increasing overall organizational risk.	
○ Evidence: No formal job description for a dedicated ISO role was provided. Organizational charts reviewed during the audit did not show an independent ISO position reporting directly to senior management or the Board. Interviews with management confirmed the absence of such a dedicated role.	
○ Recommendation: Appoint a dedicated Information Security Officer with direct reporting lines to senior management or the Board, as per NRB IT Guidelines 2023. Ensure the ISO has adequate resources and authority to implement and enforce security policies across all departments.	
○ Management Response:	

Finding 6.1.2: Web banking applications are vulnerable to session management weaknesses including session fixation.	Risk Level
	Critical
○ Risk: Session management weaknesses could allow attackers to hijack authenticated user sessions, leading to unauthorized access to customer accounts and potential financial fraud.	
○ Evidence: Technical assessment of the web banking application identified that session tokens are not regenerated after successful login, and session timeout was set to 60 minutes which is significantly longer than the recommended for bank 10 to 15 minutes.	
○ Recommendation: Implement session token regeneration upon authentication. Reduce session timeout to a maximum of 15 minutes of inactivity. Conduct regular application security testing including OWASP Top 10 assessments for all customer-facing banking platforms.	
○ Management Response:	

6.2. Network Security

Finding 6.2.1: Firewall rules contain outdated and overly permissive access rules that have not been reviewed.	Risk Level
	Critical
○ Risk: Outdate and overly permissive access rules in firewalls significantly increase attack surface allowing unauthorized access to internal systems and sensitive data of XYZ banking system	
○ Evidence: Review of firewall configuration files revealed multiple rules with “ANY-to-ANY” permission that has not been properly reviewed or updated in past 18 months. Also, no formal firewall rule review process or schedule was documented.	
○ Recommendation: Conduct an immediate review and cleanup of firewall rules following the least privilege principle. Review firewall rule process on quarterly basis and document all changes through a formal change management process.	

- **Management Response:**

6.3. Application System

• Finding 6.3.1: Mobile banking applications enforce strong authentication security such as password strength checker when registration and account lockout in login.	Risk Level
	Positive
○ Observation: The bank's mobile application enforces strong authentication security while registering it provides real-time feedback when user is giving password strong or weak password and if password is weak user can not register. Whereas in Login if user put wrong password 5 times the account will be locked out for 15 minutes which is very important to safeguard from brute force attack.	
○ Evidence: Technical review provides that bank's mobile application use NIST guidelines checklist while checking the password which includes common password also that found in data breach and lockout the account if there is 5 wrong attempt for 15 minutes.	
○ Recommendation: Continue to maintain likewise strong mobile application registration security standards.	
○ Management Response:	

• Finding 6.3.2: Multi-Factor Authentication (MFA) is not enforced on critical network systems and VPN access.	Risk Level
	High
○ Risk: Without Multi Factor Authentication, a compromised single password is sufficient for an attacker to gain unauthorized access to critical banking infrastructure, significantly increasing the risk of data breach.	
○ Evidence: Technical assessment and interviews with the Network Administrator confirmed that MFA was not enabled for VPN access, Active Directory administrator accounts, or remote desktop access to servers.	
○ Recommendation: Implements Multi-Factor Authentication for all remote access, VPN connections, privileged administrator accounts, and access to critical systems, in compliance with NRB IT Guidelines 2023 and ISO 27001:2022.	
○ Management Response:	

6.4. Vendor & Third-Party Management

• Finding 6.4.1: No formal vendor risk assessment process exists for critical third-party service providers.	Risk Level
	High
○ Risk: Without formal vendor risk assessments, the bank is exposed to supply chain risks including data breaches, service disruptions, and regulatory non-compliance caused by inadequately controlled third parties.	
○ Evidence: Review of vendor contracts and interviews with the IT Manager confirmed that no formal vendor risk assessment or due diligence process was conducted before onboarding third-party service providers. Contracts reviewed lacked specific information security clauses and data protection requirements.	

○ Recommendation: Develop and implement a formal Vendor Risk Management Policy. Conduct risk assessments for all critical third-party vendors and include mandatory information security clauses, right-to-audit provisions, and data protection requirements in all vendor contracts, as required by NRB IT Guidelines 2023.
○ Management Response:

6.5 Physical & Environmental Security

• Finding 6.5.1: Data center is equipped with robust physical access controls and environmental monitoring systems.	Risk Level
	Positive
○ Observation: The bank’s primary data center demonstrated strong physical security controls including biometric access, CCTV coverage, fire suppression systems, redundant UPS, and temperature and humidity monitoring.	
○ Evidence: Physical inspection of the data center confirmed operational biometric entry controls, 24/7 CCTV recording with 90-day retention, FM200 fire suppression system, and automated environmental alerts configured for temperature and humidity thresholds.	
○ Recommendation: Maintain the current high standard of physical security controls. Conduct periodic physical security drills and review CCTV coverage annually to ensure no blind spots exist in critical areas.	
○ Management Response:	

• Finding 6.5.2: Visitor access register is not consistently maintained, and visitor badges are not collected upon exit.	Risk Level
	Medium
○ Risk: Incomplete visitor records and uncollected access badges create a risk of unauthorized physical access to sensitive areas and make it difficult to investigate security incidents involving external visitors.	
○ Evidence: Review of the physical visitor access register revealed multiple entries with incomplete information including missing exit times and visitor purpose. Physical observation confirmed that temporary visitor badges were not systematically collected upon exit from the premises.	
○ Recommendation: Enforce a strict visitor management policy requiring complete visitor registration including name, purpose, escort, entry and exit times. Implement a formal badge collection procedure at all exit points and consider deploying an electronic visitor management system.	
○ Management Response:	

6.6 Human Resources and Administration

• Finding 6.6.1: Offboarding process lacks timely revocation of system access for departed employees.	Risk Level
	High
○ Risk: Failure to immediately revoke access for employees that departed from company creates significant risk of unauthorized access to sensitive banking systems and data by former staff, potentially leading to data theft or sabotage.	

○ Evidence: Active Directory review identified 5 user accounts belonging to employees who had left the organization, but whose accounts remained active, with the longest active period being 20 days post-departure. HR offboarding records confirmed no formal IT access revocation checklist was in use.
○ Recommendation: Implement a formal IT offboarding checklist requiring immediate account deactivation on the last working day of any departing employee. Integrate HR offboarding workflows with IT access management to ensure automated access revocation upon employee termination.
○ Management Response:

• Finding 6.6.2: Security awareness training is not conducted regularly for all staff	Risk Level
	Medium
○ Risk: Lack of regular security awareness training increases the risk of staff to falling victims to phishing attacks, social engineering and unintentional insider threats which is one of the most common causes of security incidents that happens in banking.	
○ Evidence: HR records review during the audit shows that last form of security awareness training was conductance 6 months ago. Also, there was no mandatory policy, or staff taking the security awareness training completion records especially non-IT employees.	
○ Recommendation: Implement a mandatory two times in a year security awareness training in company for all employees, even non-IT staff and add records which employee completed the training fully.	
○ Management Response:	

6.7. Business Continuity & Disaster Recovery (BCP/DR)

• Finding 6.7.1: Disaster Recovery Plan (DRP) has never been formally tested or exercised.	Risk Level
	Critical
○ Risk: An untested Disaster Recovery Plan provides no assurance that critical banking systems can be recovered within acceptable timeframes during an actual disaster which potentially result in prolonged service disruption, financial loss, and regulatory penalties.	
○ Evidence: Review of BCP/DRP documentation confirmed that while a Disaster Recovery Plan document existed no formal DR test or tabletop exercise had ever been conducted. The DRP document reviewed was last updated in 2024 and did not reflect current system configurations or Recovery Time Objectives (RTOs) for critical systems.	
○ Recommendation: Conduct an immediate DR test or tabletop exercise to validate the effectiveness of the existing DRP. Update the DRP to reflect current systems and define clear RTOs and RPOs for all critical banking applications. Schedule formal DR testing at least annually as required by NRB IT Guidelines 2023.	
○ Management Response:	

7. Conclusion

This Information System Audit of XYZ Bank Limited was conducted to evaluate the effectiveness of the bank's IT governance, security controls and operation resilience across seven key domains. The audit revealed that while the bank has made a notable effort in certain areas of information security particularly in physical security and mobile application controls but there remains a significant vulnerability that requires immediate management attention.

In Audit the most critical concerns identified include outdated and overly permissive firewall rules that expose the bank's internal network to unauthorized access and session management weakness found in the web banking application that could enable session hijacking attacks, and also the absence of any formal testing of the Disaster Recovery Plan which is a mandatory requirement under NRB IT Guidelines 2023. Additionally, the lack of a dedicated ISO Information Security Officer, absence of Multi Factor Authentication on critical systems, no formal vendor risk assessment process and delayed revocation of system access for departed employees immediately represent significant High-risk gaps that must be addressed quickly to protect the bank's operations, customer data, and compliance with regulatory bodies.

On a positive note, the bank shows strong security practices in the areas of mobile banking application authentication or registration and data center physical security controls. These strengths should be properly maintained and updated in the industry security standard on the world.

It is the opinion of the audit team that XYZ Bank Limited should treat the remediation of Critical and High risk finding as an immediate organizational priority. The bank is encouraged to develop a formal remediation plan with assigned ownership and clear timelines for each finding. A follow-up review is recommended within six months to verify that identified findings have been adequately addressed. The audit team expresses sincere gratitude to the management and staff of XYZ Bank Limited for their full cooperation and support throughout the audit engagement.